HL-CYB-001

Security requirements and threat model

Enterprise Zero Trust Security Architecture

Document version a1f56f742827

PLANNED - operational controls NOT TESTED

Status: PLANNED controls; operational effectiveness NOT TESTED. These requirements protect the lab's boundaries, privileged access, and engineering evidence. They define what later implementation must demonstrate; they do not establish compliance or show that a control is already working.

Use this document with the architecture, test plan, and glossary. The tables keep the exact security IDs and standards mappings used for traceability.

1. Assets, actors, and boundaries

Protect the boundary with home/production, administrator rights, directory/service credentials, certificate authority (CA) keys, synthetic application data, access decisions, audit records, backups, and public repository contents. Synthetic data does not make lab passwords or private keys safe to publish. Corporate Microsoft 365, PE-DAP, corporate web/hosting, and customer data are excluded and are never test targets.

Consider authorized users and administrators, stolen lab accounts, compromised endpoints/connectors, administrator mistakes or misuse, untrusted remote clients, and altered software/dependencies. Check each place where trust changes: physical connectivity, Management versus workloads, the six virtual zones, permissions inside a zone, directory versus PKI administration, the remote-access provider versus the lab resource, and private evidence versus public Git.

Assume an ordinary endpoint may be compromised and a vendor default may allow too much access. Multi-factor authentication (MFA) does not eliminate credential theft; the firewall may not see same-zone or overlay traffic; encryption does not grant permission; one project owner cannot provide full organizational separation of duties. A compromised hypervisor administrator could defeat virtual isolation. Physical production separation and private recovery reduce the consequences but do not remove that risk.

2. Mandatory security requirements

Table 1. Mandatory security requirements

Security ID	Requirement	Project requirements / tests
S01	Default-deny every network boundary, including egress and management; inspect inherited/automatic rules, local listeners, state, and IPv6	R01, R03, R04; T01, T02, T04, T06
S02	Use lab-only identities/resources; no production trust, federation, sync, corporate SSO, credential reuse, or production data	R01, R05, R09; T01, T07, T13, T14
S03	Separate standard/admin/service identities; group-based privileges and resource authorization; review lifecycle and revocation	R05, R06, R08; T08, T09, T12
S04	Require supported management/remote MFA and protected recovery; identify paths where MFA is unavailable	R03, R09; T04, T13, T14
S05	Use an offline standalone root, scoped issuing CA/templates, lab-only trust, internal CRL/AIA, and application-specific validation	R07; T10, T11
S06	Constrain DNS to approved lab resolvers; do not forward lab/corporate namespaces externally or permit alternate resolver bypass by default	R01, R05; T02, T07

Security ID	Requirement	Project requirements / tests
S07	Keep secrets, actual addresses, keys, backups, raw evidence, and tenant identifiers outside public Git; use secure credential stores	R11, R16; T00, T17
S08	Collect relevant events with authenticated transport, controlled access, UTC correlation, rotation, and source-health detection	R10; T15, T16
S09	No inbound Internet administration, port forwarding, UPnP/NAT-PMP, broad subnet exposure, exit-node routes, or unapproved overlay paths	R01, R09; T02, T13, T14
S10	Review supported versions/media integrity/patch status and avoid unreviewed scripts; limit CI token permissions and pin actions	R02, R03, R11, R16; T03, T17
S11	Encrypt off-compute backups and verify supported identity/PKI restoration before claiming recovery	R13; T19
S12	Approve every stage, stop on unexpected impact, preserve evidence, and separate engineering verification from owner UAT	R14, R15; T20

3. Threat register

Table 2. Threat register

ID / scenario	Boundary and preventive treatment	Detection / safe verification	Residual risk and owner
TH01: accidental route/bridge reaches home or production	Physical/virtual boundary; offline baseline, private protected aliases, independent egress gate, no general guest uplink	Configuration/cable/route review and lab mock denial, T01/T02	Host/admin error can bypass design; owner approves topology
TH02: compromised ordinary endpoint moves laterally	Inter-zone plus same-zone host/application boundary; default deny, scoped AD dependencies, role authorization	Denied-flow/application audit and twelve-case matrix, T06/T12	Same-subnet traffic bypasses virtual firewall; engineer reviews host controls
TH03: stolen privileged credentials	Management/identity boundary; separate admin path, supported MFA, delegated rights, protected break-glass	Administrative logon/change alerts, T04/T08	MFA gaps and console/key theft remain; owner owns recovery custody
TH04: misconfigured PKI permits identity impersonation	CA boundary; offline root, restricted templates/EKUs/SANs/enrollment, private keys	Template/issuance audit, valid/untrusted/revoked application tests, T10/T11	Single owner and no HSM; owner accepts lab limitation
TH05: remote connector or permissive vendor policy exposes extra assets	Remote/resource boundary; separate lab environments, explicit resource ports, connector-zone firewall, no advertised routes	Effective-policy review plus unauthorized/revoked tests, T13/T14	Vendor outage, plan limits, cached sessions, overlay bypass; engineer records gaps

ID / scenario	Boundary and preventive treatment	Detection / safe verification	Residual risk and owner
TH06: DNS/time bypass undermines policy or authentication	Infrastructure dependency boundary; lab-only resolver/time hierarchy, restricted forwarding/egress	DNS/clock inspection, local mock bypass checks, T07/T15	Encrypted DNS/application fallbacks and offline drift; owner decides exceptions
TH07: credential or proprietary artifact is published	Private/public boundary; outside-repo custody, staged/history review, ignore rules, focused scanner	T00/T17 plus manual content/metadata review	Pattern scans miss novel secrets; publishing operator reviews each artifact
TH08: audit data is missing, modified, or too large	Workload/collector boundary; constrained submission/admin, authenticated transport, rotation and alerts	Twenty-event correlation, missing-source test, T16	Single-host compromise/clock drift; immutable storage deferred
TH09: malicious or altered dependency/install media	Supply-chain boundary; official media integrity, supported updates, reviewed action SHA, minimal dependencies	Version/integrity ledger and CI permission review, T03/T17	Upstream compromise and unpatched offline hosts; owner reviews update exceptions
TH10: failure destroys directory, PKI, or evidence	Recovery boundary; encrypted off-compute supported backups and key custody	Timed isolated restore and synthetic consistency checks, T19	One disk/host, unverified backup capacity, evaluation expiry; owner funds/accepts scope
TH11: CI or automation targets live systems	Repository/lab boundary; documentation-only hosted runner, no lab secrets, explicit automation target allowlist	Workflow/code inspection, invalid-target tests, T17/T18	Reviewer/privileged error; owner approval required for scope changes

4. Tailored control matrix

NIST SP 800-207 tenet labels below are abbreviated project references: T1 resource inventory, T2 secured communication, T3 per-session resource access, T4 dynamic policy, T5 asset posture, T6 authentication/authorization before access, T7 telemetry and improvement. These labels do not rename this project's test IDs.

Table 3. Tailored control matrix

Project outcome	SP 800-207 tenets	SP 800-53 Rev. 5 example controls	CIS Controls v8.1	Verification
R01/R04 protected boundaries and default deny	T1, T2, T3	AC-4, SC-7	12 Network Infrastructure Management; 13 Network Monitoring and Defense	T01, T02, T05, T06
R02/R03 inventory, hardened management, integrity	T1, T5, T6	CM-2, CM-6, CM-8, SI-2	1 Enterprise Assets; 2 Software Assets; 4 Secure Configuration; 7 Vulnerability Management	T03, T04

Project outcome	SP 800-207 tenets	SP 800-53 Rev. 5 example controls	CIS Controls v8.1	Verification
R05/R06/R08 identities, endpoint rights, lifecycle	T3, T4, T5, T6	AC-2, AC-3, AC-6, IA-2, IA-5	5 Account Management; 6 Access Control Management; 4 Secure Configuration	T07, T08, T09, T12
R07 PKI/trust and encrypted resource access	T2, T6	SC-12, SC-13, SC-17, IA-5	3 Data Protection; 6 Access Control Management	T10, T11
R09 scoped remote access and revocation	T2, T3, T4, T5, T6	AC-17, AC-3, IA-2, SC-7	6 Access Control Management; 12 Network Infrastructure Management	T13, T14
R10 audit/time/monitoring	T7	AU-2, AU-6, AU-8, AU-9, AU-12, SI-4	8 Audit Log Management; 13 Network Monitoring and Defense	T15, T16
R11/R16 safe publication and workflow	T1, T6, T7	AC-6, CM-3, SA-10, SA-11	3 Data Protection; 4 Secure Configuration; 16 Application Software Security	T00, T17
R12/R13 repeatability and recovery	T5, T7	CM-3, CP-9, CP-10	4 Secure Configuration; 11 Data Recovery	T18, T19
R14/R15 assessment, risk, and evidence	T7	CA-2, CA-7, RA-3	8 Audit Log Management; 17 Incident Response Management	T20 and all applicable tests

Each mapping identifies an aspect the project intends to study. It does not show that an entire NIST control, CIS Control, safeguard, implementation group, or baseline is satisfied, and it is not an official equivalence or CIS Safeguard-level mapping. References: NIST 800-207, NIST 800-53 Rev. 5, NIST Release 5.2.0 notice, and CIS Controls v8.1. Recheck versions before implementation.

5. Publication and incident handling

Before committing/pushing, review the entire candidate set and staged diff, validate relative links/structure, scan selected secret patterns and private address literals, inspect public evidence metadata, and confirm that no production exports or proprietary source exist. Review history before first publication; ignore rules cannot erase historical secrets. Hosted CI is a second check after publication, so it cannot replace the prepublication review.

The standard-library scanner is intentionally bounded: it is not an entropy-based or vendor-complete secret detector, proprietary-code classifier, external link checker, live network validator, or image metadata sanitizer. Unknown file types fail closed. New binary evidence requires a reviewed validator extension and a manual artifact review; raw media remains private. Do not weaken checks to accommodate a finding.

If a secret or protected detail is found, stop publication and quarantine the affected artifact privately. If exposed, rotate/revoke the credential through the authorized owner process; deletion alone does not invalidate it. Record the incident privately and obtain approval before rewriting history or contacting others. Recheck the sanitized artifact and Git history. Task 001 authorizes no production incident operation.